

FortiGate-40F Initial Setup, OS Image Transfer and Basic Security with minimal Configuration



By Rui Yang

Purpose:

The purpose of this lab is to setup a FortiGate 40f completely from nothing and being able to transfer an image of the OS onto it, accessing the Web GUI, and setup for a very simple and minimal configuration setup to make it slightly more secure.

Background Information:

Next-generation firewalls (NGFWs) such as the FortiGate 40F are widely deployed in small office/home office (SOHO) environments. The FortiGate 40F is a compact, fan-less desktop unit produced by Fortinet that runs FortiOS, a purpose-built security operating system. Unlike general-purpose router-firewalls, the 40F is designed to enforce security policies using Fortinet's proprietary Security Processing Units (SPUs), which offload compute-intensive tasks such as SSL/TLS inspection and IPS signature matching from the main CPU.

Sometimes, a network administrator may need to recover a unit with a corrupted or incompatible OS/firmware. In these cases, the standard recovery mechanism is a TFTP (Trivial File Transfer Protocol) firmware transfer. TFTP is a file transfer protocol that operates over UDP port 69. Because it requires no authentication, it is well suited for early-boot environments where the firewall is not yet initialized. During the boot process, the FortiGate 40F enters a recovery menu accessible by a serial console connection that allows an operator to specify a TFTP server address and initiate a firmware download before the main OS boots. The TFTPd64 application, a widely used open-source TFTP server for Windows, is used in this lab to serve the FortiOS image file to the firewall over a direct Ethernet connection to the Firewall.

Once FortiOS is successfully loaded, the FortiGate 40F has a Web-based Graphical User Interface (Web GUI) accessible at a default management IP address of 192.168.1.99. This interface provides administrators with a dashboard for configuring network interfaces, security policies, routing, and system services without requiring expertise in the command-line interface (CLI). By default, the FortiGate 40F comes with a preconfigured SOHO template that places all the LAN ports into a single hardware switch interface and applies basic NAT policies so that connected clients can immediately

access the internet. While this configuration simplifies the initial deployment, it offers a relatively flat network structure where management traffic and end-user data traffic share the same interface set, which is generally considered a poor security practice.

Management plane separation is a security baseline practice which isolate the traffic used to administer a device from the traffic generated by end users. On the FortiGate 40F, this is achieved by removing LAN ports from the default software switch, creating a dedicated interface set for client-facing traffic, and reserving a separate physical port exclusively for administrative access. This prevents a scenario in which a compromised or malicious client on the LAN can directly reach the firewall's management interface, which could allow brute-force attacks against the admin login, exploitation of management-plane vulnerabilities, or unauthorized configuration changes. Segmenting the management port also reduces the attack surface of the device by limiting which network segments can initiate sessions to the Web GUI.

Security policies on the FortiGate define what traffic is permitted to flow between interfaces or zones, and they form the core enforcement mechanism of the firewall. After separating the management interface from the LAN, a new security policy must be created to allow the newly defined LAN interface set to route traffic to the WAN interface and reach the internet. Fortinet's default security policies include a set of baseline Application Control and Web Filtering profiles that provide an initial layer of content inspection on outbound traffic. These profiles, while not highly restrictive by default, ensure that all outbound sessions pass through Fortinet's inspection engine, providing visibility and basic threat prevention without requiring manual rule creation. The result is a simple, but slightly more secure SOHO deployment compared to the factory default settings.

Lab Summary:

In this lab, we performed a configuration and deployment of a FortiGate 40f firewall from scratch, starting with a TFTP-based OS image transfer and culminating in a baseline hardened SOHO configuration. We started by setting up the TFTP64 server on a Windows machine, configuring it to serve the correct FortiOS image file, and connecting the machine directly to the firewall via Ethernet. We then accessed the FortiGate's pre-boot recovery console through a serial connection, configured the TFTP parameters

including the server IP, local IP, subnet, and gateway, and initiated the firmware transfer to flash the OS onto the device.

After the firmware transfer completed and the firewall rebooted into FortiOS, we accessed the Web GUI at the default management address of 192.168.1.99 and completed the initial login process, setting a new administrator password to satisfy FortiOS's password policy requirements. For now, the FortiGate was running its default SOHO configuration with all LAN ports set into a single software switch interface. To improve the security posture above the factory defaults, we first removed the LAN interfaces from the default software switch to break the flat network topology. We then created a new interface group and added those ports into it, creating a dedicated client-facing interface set that is separated from the management port. Following that, we configured a security policy for the new interface group to allow outbound internet traffic through the WAN interface, with Fortinet's default security inspection profiles applied to all outbound sessions. This configuration ensures that all client devices connected to the firewall can still reach the internet while unable to access the Web GUI, and that all outbound traffic is subject to basic application-layer inspection by the FortiGate's security engine.

Steps and Configuration:

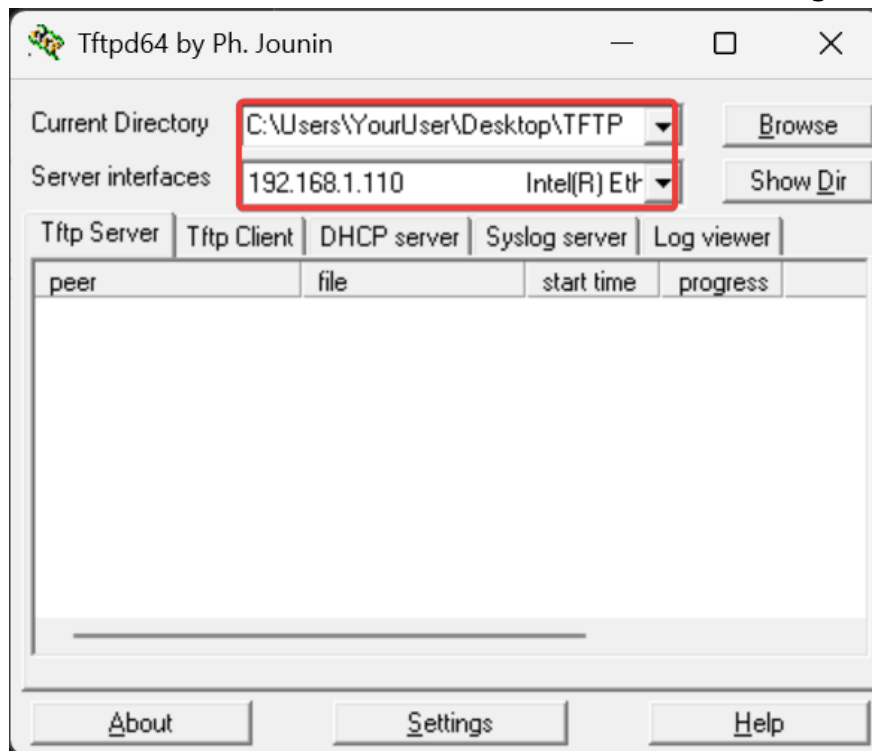
Step 1: Reset the Firewall from a no-OS state with a TFTP transfer of the correct OS image. If your firewall has a pre-existing operating system, please skip to step 2

Setting Up the TFTP Server:

For this report, the computer is utilizing Windows OS, and the TFTP server option used was TFTP64.

1. Install TFTP64 from the official github page:
<https://pjo2.github.io/tftpd64/> and follow the instructions provided.
2. Connect your desktop to the Firewall
3. Open TFTP64 and selected the current directory to the path to the location of your Fortigate ISO file

4. Set the Server interfaces to the interface connecting to the Firewall.



Configuring the Firewall to get ready for TFTP:

1. Enter fortigate configuration menu from the command line interface.
2. Press C to start configuring TFTP parameters.
3. Press P to set the Firmware download port
4. Set the image download port number to specific port; default is port 1.
5. Set the Remote TFTP Server IP to the address of the ethernet port on your desktop.
6. Set the local gateway to the IP address of the ethernet port on your desktop
7. Set the local IP address to an IP address within the subnet of the address block used.
8. Set the local subnet to match that of the address block used.

9. Go back to the initial configuration menu and press T to initiate the TFTP firmware transfer.

```
Please wait for OS to boot, or press any key to display configuration menu..

[C]: Configure TFTP parameters. ←
[R]: Review TFTP parameters.
[T]: Initiate TFTP firmware transfer.
[F]: Format boot device.
[I]: System information.
[B]: Boot with backup firmware and set as default.
[Q]: Quit menu and continue to boot.
[H]: Display this list of options.

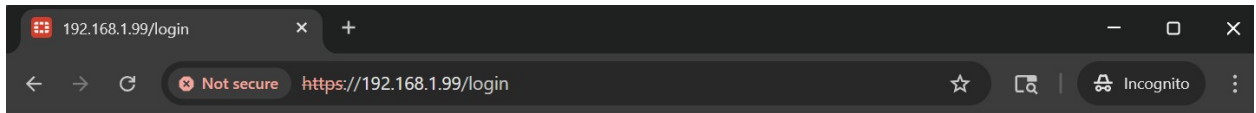
Enter C,R,T,F,I,B,Q,or H:

[P]: Set firmware download port. ←
[D]: Set DHCP mode.
[I]: Set local IP address.
[S]: Set local subnet mask.
[G]: Set local gateway.
[V]: Set local VLAN ID.
[T]: Set remote TFTP server IP address.
[F]: Set firmware file name.
[E]: Reset TFTP parameters to factory defaults.
[R]: Review TFTP parameters.
[N]: Diagnose networking(ping).
[Q]: Quit this menu.
[H]: Display this list of options.

Enter P,D,I,S,G,V,T,F,E,R,N,Q,or H:

[0]: port 1 ←
[1]: port 2
[2]: port 3
[3]: A
[4]: WAN
Enter image download port number [port 1]:0 ←
```

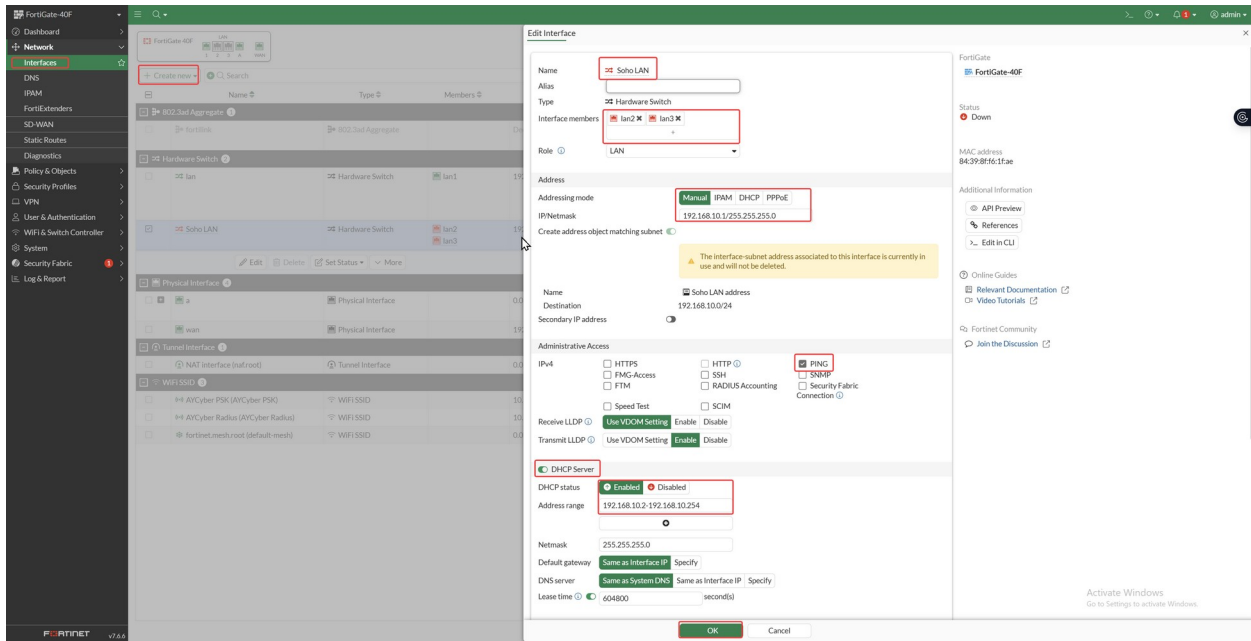
Then you should be able to connect to the FortiGate Web GUI. The default ip for the GUI is shown here, being 192.168.1.99. If it doesn't work, make sure that your device ethernet IP connecting to the firewall management is configured to be inside the same subnet as the firewall management IP. The default logins are Username: Admin and Password: (blank)

A login form overlay with a green header containing the FortiGate logo. Below the header are two input fields: 'Username' and 'Password'. The 'Password' field has a small eye icon to its right. At the bottom of the form is a green button labeled 'Login'.

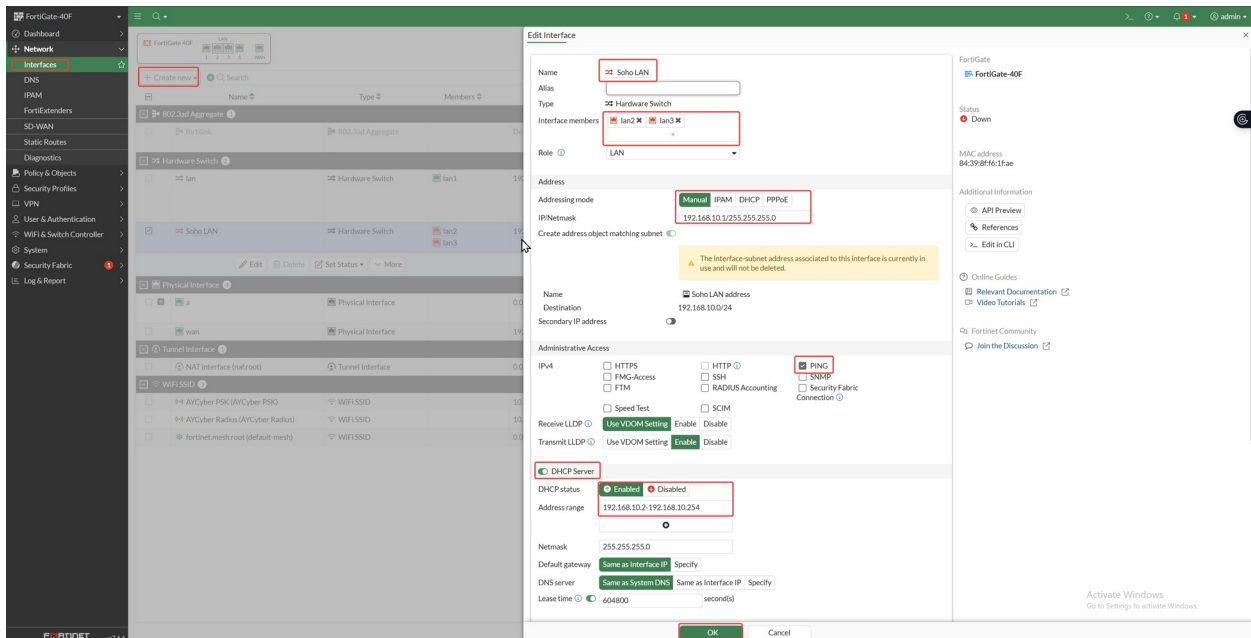
Normally, the FortiGate 40f firewall will have you change the password of the default login from blank to something. If that occurs, just create a password that follows the FortiGate password creation requirements.

FortiGate 40f comes with a preconfigured SOHO configuration, so if simplicity is what you are looking for, you can stop here. However, a few simple measures can be taken to increase the security of the Firewall. First of which is specifying and splitting the management port from the LAN port range.

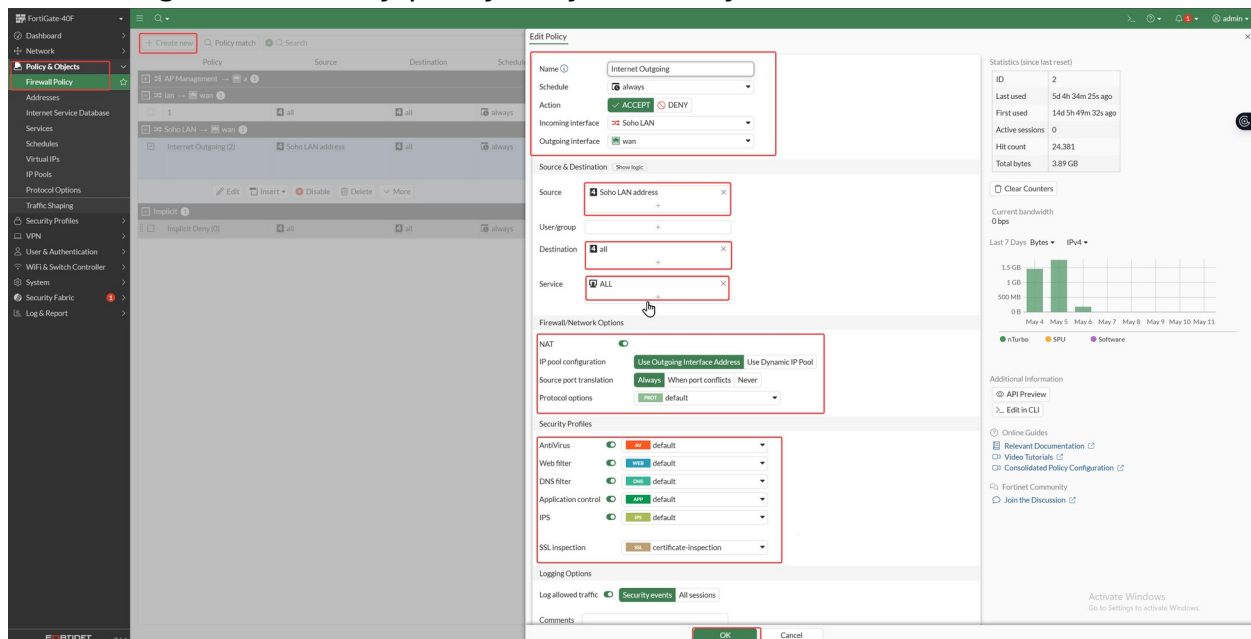
Step 1: Remove the LAN interfaces from the default LAN



Step 2: Add a new interface and add those removed interfaces into the new interface:



Next, configure a security policy for your newly created interface set:



That's it for a very simple SOHO configuration of a FortiGate 40f! All devices connected to the firewall should be able to connect to the internet and the public address should all be NATed and all traffic going out to the internet should have to conform to the default security profiles set by Fortinet.

Problems:

Very Simple lab design, setup and configuration. Minimum setup required, and no problems were encountered. There were some small issues with the TFTP process where an image had to be transferred, but that was easily fixed by reading some official guides by Fortinet or online guides from the networking community.

Conclusion:

We managed to fully set up a FortiGate 40f from scratch. We were able to TFTP an image onto the firewall through the TFTP64 app and then configured basic policies and configurations on the FortiGate to make it slightly more security than the base default setup.